

Identity Security Test Matrix — AuthShield 360 v2 (Enterprise)

Functional verification map for the v2 mandate (registration + real e-mail verification, trusted-device designation, cross-device approval, 0–100 contextual risk with reasons, SOC sidebar, attack types A/B/C, role-split dashboards, school portal + RBAC, account recovery/MFA reset, digital forensics, authentication benchmark, restart persistence).

Each row maps to a reproducible check via `scripts/smoke.js`, `scripts/e2e-all.js`, `scripts/ui-smoke.js` or `scripts/restart-check.js`. Total automated coverage: **140 checks**.

TC-RSK — Adaptive Risk Scoring Engine (0–100, reasons[])

ID	Factor	Weight	Band	Evidence
RSK-01	F_TIME_ANOMALY (outside 07:00–23:00)	+15	combos	/api/factors ledger
RSK-02	F_NEW_IP (subnet unseen for user)	+25	combos	incognito login reasons=NEW_IP
RSK-03	F_NEW_DEVICE (unknown fingerprint) alone	+30	LOW (≤30)	smoke risk unit
RSK-04	F_UNRECOGNIZED_DEVICE	+30	combos	cross-device pending shows reasons
RSK-05	F_CONSECUTIVE_FAILURE per attempt	+20	2nd ⇒ +40	Type-A sim: 55 → 75 → block
RSK-06	F_IMPOSSIBLE_TRAVEL (> 1,000 km/min)	+40	HIGH combo	Type-B sim (SF→SYD ≈12,000 km)
RSK-07	F_BLACKLISTED_IP	+45	HIGH	Type-C sim + manual blacklist
RSK-08	Score clamp	0–100	—	evaluateRisk unit
RSK-09	Band LOW 0–30 → direct (S1) / S2	S3 step-up	—	S1 warm SUCCESS
RSK-10	Band MEDIUM 31–69 → Cross-Device Approval / fallback OTP+Email	—	incognito login → PENDING_APPROVAL (score 55)	

ID	Factor	Weight	Band	Evidence
RSK-11	Band HIGH 70–100 → immediate lockdown + admin alert	—	Type-A/B/C end states + /api/dashboard ALERTS	

TC-VER — Registration → E-Mail Verification → Trusted Device

ID	Step	Expected	Evidence
VER-01	POST /auth/register	<code>verification_pending</code> , verifyUrl issued, Nodemailer written (Ethereal preview when online, console when offline)	e2e + smoke
VER-02	Store verification token (single use, TTL)	row in verification_tokens	db
VER-03	GET /verify?token=	user <code>email_verified=1</code> ; <code>Set-Cookie as360_trust</code> (HttpOnly, SameSite=Lax, 1y)	e2e "cookie: YES"
VER-04	GET /me (with cookie)	<code>trusted:true</code> + user identity	e2e
VER-05	Re-verify stale/used token	rejected	verifyEmail guard
VER-06	Auto-trust after OTP-verified new device	device row added	auth.js \$SUCCESS

TC-XDA — Cross-Device Approval (Apple/Google style)

ID	Step	Expected	Evidence
XDA-01	Untrusted device login at MEDIUM risk	<code>PENDING_APPROVAL</code> + pendingId + fallbackAt	e2e risk=55
XDA-02	Trusted device sees prompt	SSE <code>cross:<uid></code> event (device, IP, location, risk, reasons)	stream-test
XDA-03	Approve	pending → <code>approved</code> ; finalize → <code>SUCCESS</code> + session	e2e finalize SUCCESS
XDA-04	Deny	pending → <code>denied</code> ; finalize blocked (<code>not_approved</code>)	e2e
XDA-05	Timeout	status → <code>expired</code> ; UI falls back to E-mail + OTP	pendingStatus guard + UI
XDA-06	Approved device becomes trusted	device row for new fp	finalize addTrustedDevice
XDA-07	Polling	GET /pending/:id/status	e2e

TC-SCN — Mandatory SRS Scenarios (preserved)

ID	Scenario	Expected	Status
SCN-1A	S1 correct pw (trusted, known network)	SUCCESS no MFA	PASS
SCN-1B	S1 wrong pw	FAILED_PASSWORD	PASS
SCN-1C	S1 2× wrong pw → lock; 3rd attempt	HIGH_RISK_BLOCK	PASS
SCN-2A	S2 pw → step-up	STEP_UP needsOTP	PASS
SCN-2B	S2 valid OTP	SUCCESS	PASS
SCN-2C	S2 bad OTP	INVALID_OTP (no lock)	PASS
SCN-3A	S3 pw → step-up OTP+Email	STEP_UP needsOTP+needsEmail	PASS
SCN-3B	S3 pw + OTP + email	SUCCESS	PASS
SCN-3C	S3 RBAC	STUDENT→admin route HIGH_RISK_BLOCK	PASS (manual)

TC-AUD — Granular Audit Logging (every attempt)

Field	Present	Example
Timestamp (ISO)	✓	2026-09-25T13:5x:xx.000Z
Identity / role / user id	✓	teacher2 / TEACHER / usr-...
Device label + browser/UA	✓	'Unknown Device', desktop UA
Fingerprint hash	✓	fp:...
Network IP / subnet / label	✓	45.55.200.100 / - / San Francisco
Outcome	✓	SUCCESS / FAILED_PASSWORD / INVALID_OTP / STEP_UP / HIGH_RISK_BLOCK
Risk 0–100 + reasons[]	✓	55 / ["NEW_IP","UNRECOGNIZED_DEVICE"]

TC-SIM — Attack Simulation Engine (Types A/B/C)

Type	Name	Telemetry	End state
A	Brute-Force Spray	3 fast wrong-pw: risk 55 → 75 → 100	Account quarantined, HIGH alerts
B	Impossible-Travel Blitz	SF login → SYD 12 s later ⇒ travel ≈12,000 km	HIGH ⇒ lockdown
C	Credential-Stuffing Replay	correct pw from blacklisted IP + new device	HIGH ⇒ blocked regardless of password

All simulations drive the **real** `attemptAuthentication` pipeline, stream each phase over SSE, and update `/api/dashboard` counters + `/api/alert`s live.

TC-SOC — Role-aware dashboards

ID	Role	Surface
SOC-01	ADMINISTRATOR	sidebar (Overview/Audit/Sessions/Trusted Devices/Threat Factors/Blacklist/Attack Sim), gauges, toasts

ID	Role	Surface
SOC-02	STUDENT / TEACHER	Security Center: verified status, my devices (revoke), my sessions (end), recent activity

TC-RBA — School Portal — Role-Based Access (v2)

ID	Check	Expected	Result
RBA-01	<code>GET /api/portal/session</code> no session	401 <code>SESSION_REQUIRED</code>	e2e
RBA-02	STUDENT grades / courses / attendance	200, own data only	e2e
RBA-03	STUDENT rosters / users / matrix	403 <code>PORTAL_RBAC_DENIED</code>	e2e
RBA-04	TEACHER rosters	200 (own courses)	e2e
RBA-05	TEACHER matrix / users	403	e2e
RBA-06	ADMIN matrix	200, 8 modules	e2e + ui-smoke
RBA-07	ADMIN users / rosters (all rows)	200	e2e
RBA-08	Data scoping SQL (teacher/subnet filters)	row-filter injection	portal.js/db.js review
RBA-09	Scenario-3 STUDENT route lock	<code>HIGH_RISK_BLOCK</code> + <code>UNAUTHORIZED_ROUTE</code>	e2e
RBA-10	Admin control plane gate (lists/factors/forensics)	403 <code>ADMIN_SESSION_REQUIRED</code> w/o active SID	e2e

TC-REC — Account Recovery / MFA Reset (v2)

ID	Step	Expected	Result
REC-01	<code>POST /api/recovery/request</code>	<code>ok</code> , 6-digit verifyCode, persisted	e2e
REC-02	Reset with wrong code / weak pw	rejected	e2e
REC-03	<code>POST /api/recovery/reset</code>	TOTP rotated, pw changed, 10 single-use codes	e2e
REC-04	<code>POST /api/recovery/validate</code> (code once)	1st <code>ok</code> , 2nd <code>false</code> (consumed)	e2e
REC-05	Login with new password	<code>SUCCESS</code> (device still trusted)	e2e
REC-06	Login with old password	<code>FAILED_PASSWORD</code>	e2e
REC-07	Audit trail	<code>RECOVERY_REQUEST/RESET/CODE_VALID</code> rows	e2e \$12

TC-FOR — Digital Forensics (v2)

ID	Step	Expected	Result
FOR-01	<code>GET /api/forensics/summary</code>	live counters (audit/sessions/devices/cases)	e2e
FOR-02	<code>GET /api/forensics/timeline?user=</code>	chronological events (kind/ref/ts)	e2e
FOR-03	Create case (auto-capture)	case.id + evidence items captured	e2e + ui-smoke
FOR-04	List cases	per-case <code>items</code> counter	e2e
FOR-05	Case timeline	evidence from captured audit rows	e2e
FOR-06	Close case	status <code>CLOSED</code>	e2e
FOR-07	Export evidence	<code>ok</code> + <code>markdown</code> (<code># Forensic Case</code> , <code>Evidence timeline</code>)	e2e + restart-check
FOR-08	Delete case	gone from list	e2e

TC-BEN — Authentication Benchmark (v2)

ID	Check	Expected	Result
BEN-01	<code>GET /api/benchmark</code>	<code>ok</code> , 3 scenarios	e2e
BEN-02	Per scenario	attempts $\geq$ 1, <code>averageLoginTimeMs</code> , success counter	e2e
BEN-03	Measured from real <code>elapsed_ms</code>	no fixtures	benchmark.js review + restart-check

TC-NFR — Restart Persistence (v2, availability)

ID	Check	Expected	Result
NFR-01	Hard-restart on same SQLite file	users + trusted devices survive	restart-check
NFR-02	Audit trail (incl. <code>elapsed_ms</code>) survives	count $\geq$ pre-restart	restart-check
NFR-03	Sessions / devices survive	counters persist	restart-check
NFR-04	TOTP secrets survive	user can still log in post-restart	restart-check
NFR-05	Forensic cases + evidence survive	case + export still ok	restart-check
NFR-06	Attack runs survive	history intact	restart-check

Tooling notes

- Manual equivalence is 1:1 against the public JSON API — Burp Suite / OWASP ZAP target `http://localhost:4000/api/`.
- To lift brute-force guards while probing: log in as `admin` (S3, DEMO-panel OTP), then

`PUT /api/security-policy?standby=false` and `POST /api/arm-mode (x-session-side: <sid>)`.

- Automated harness: `scripts/smoke.js` (17; no server), `scripts/e2e-all.js` (77; live server),

`scripts/ui-smoke.js` (28; real browser), `scripts/restart-check.js` (18; isolated port 4001). Clean-run recipe:

kill `:4000` → `node scripts/reset-db.js` → `npm start` → run the four suites.